CASE STUDY

Collabora Built-in CODE Server (richdocumentscode), CVE-2026-110447: Lab-Verified Exposure and Fix

A TeamStarWolf case study. Published 4 November 2026; every source checked as of that date.

Executive summary

Self-hosters who run Nextcloud with its office suite often take the easy path: install the Nextcloud Office connector (`richdocuments`) and, beside it, the "Collabora Online - Built-in CODE Server" app (`richdocumentscode`), which ships a whole Collabora Online Development Edition server inside a Nextcloud app. CVE-2026-110447 lives in that second app, not in the connector. Its `proxy.php` built the command that launches the bundled server by placing request-derived values inside a double-quoted `bash -c` string, so an unauthenticated request could make the web server user run a command of the attacker's choosing whenever the bundled server was not already running: after a container restart, an upgrade or a crash (**Confirmed** [1][2][9]).

The record has an uncomfortable shape. The fix was written in August, shipped on 11 September 2026 as 26.4.303 without any security label, and the advisory followed 33 days later, on 14 October (**Confirmed** [1][11][13]). In between, victim administrators were reporting web shells on a public GitHub issue: the first logged attack request is dated 10 September 2026, less than a day before the fixed release (**Confirmed** [18]). CISA added the flaw to its Known Exploited Vulnerabilities catalog on 23 October with a three-day due date and a forensic triage flag (**Confirmed** [4]). No vendor, CERT or research firm has attributed the activity, and no primary source gives a count of affected servers (**Confirmed** [1][3][4][18]).

On 4 November 2026 TeamStarWolf ran a vulnerable 26.4.302 build and a fixed 26.4.303 build side by side in two loopback-only containers. The lab confirmed the fix in the running proxy.php, showed that a version-floor check separates the vulnerable build from the fixed one, and turned up two traps in the obvious checks: `occ`

cannot list apps on an instance that was never installed, and a 404 at the `/apps/` path does not mean the app is absent (**Demonstrated** [44][45][46]). Exploitation itself was not exercised.

> Evidence grade: the flaw, the fix and in-the-wild exploitation are **Confirmed** from the vendor advisory, the CVE and NVD records, CISA KEV and the victims' own reports; the ransomware link is **Reported** and unverified; the lab readings are **Demonstrated**.

Key facts at a glance

Field	Value
Identifier	CVE-2026-110447; Collabora advisory GHSA-g3vx-3m76-fghh; GitHub global advisory GHSA-f97p-r72q-64h2 (an unreviewed NVD mirror) [1][2][6]
Vulnerable component	Nextcloud app `richdocumentscode`, "Collabora Online - Built-in CODE Server", vendor Collabora; not the `richdocuments` (Nextcloud Office) connector [2]
Class	Unauthenticated OS command injection through `proxy.php` (CWE-78), runs as the web server user [1][3]
Precondition	The built-in CODE server (coolwsd) is not running: restart, upgrade or crash [1]
Affected	`richdocumentscode` below 26.4.303 [1][3]
Fixed	26.4.303 (11 September 2026); hardening in 26.4.402 (24 September) and 26.4.502 (23 October) [13][16][17]
Not a fix	Disabling the app; it must be upgraded or removed [1]
Not affected	Standalone Collabora Online servers [1]
Severity	CNA CVSS 4.0 9.2 Critical; NVD CVSS 3.1 9.8 Critical [2][3]
SSVC (CISA, 23 Oct 2026)	Exploitation active, Automatable yes, Technical Impact total [2][3]
CISA KEV	Added 23 October 2026, due 26 October 2026, ransomware use Unknown, forensic triage Yes [4]
First logged exploitation	10 September 2026, 19:51 +0200, against a server on 26.4.302 [18]
Attribution	None in any primary opened [18]
Lab result	26.4.302 flagged VULNERABLE, 26.4.303 FIXED by a version-floor check; fix confirmed in the running `proxy.php` [44][46]

Key findings

- **The flaw is in the built-in CODE server app, and the name matters for asset searches.** The CVE record names `richdocumentscode`, titled "Collabora Online - Built-in CODE Server", from Collabora's `richdocumentscode` repository, distributed through apps.nextcloud.com (**Confirmed** [2]). An inventory that only looks for "Nextcloud Office" or `richdocuments` misses it.

- **Quoting each value was not enough.** In 26.4.302 the Host header and the font-config URL went through `escapeshellarg()` and were then dropped inside an outer double-quoted `bash -c` string (**Confirmed** [9]). Inside double quotes the single quotes are literal, so the outer shell still expanded command substitution from the request (**Inferred** from [9] and [12]). The fix escapes the whole inner command once more before `bash -c` (**Confirmed** [11]; **Demonstrated** [46]).
- **The patch shipped silently and the warning came a month later.** The fix commit is titled as a tidy-up, and neither it nor the 26.4.303 changelog says "security" (**Confirmed** [11][14]). The advisory followed the fix by 33 days (**Confirmed** [1][13]).
- **Attacks started before the fix and kept coming after it.** The first logged request came on 10 September; requests from a second address reached a host already on 26.4.303 on 14 September; ModSecurity blocked attempts for one user on 16 October; and on 30 October a user reported the attack working against a disabled, not-updated app (**Confirmed** [18]; ModSecurity report **Reported**).
- **What attackers did is known from victims, not from a vendor report.** Victims described encoded shell commands in the URL path, one-line PHP web shells in the app folder, callbacks to webhook.site carrying `uname -a` output, and on one host searches for password databases and coin wallets (**Confirmed** as first-hand reports [18]).
- **Disabling the app is not a fix.** The advisory says a disabled app below 26.4.303 is still exploitable, so it must be upgraded or removed; 26.4.502 additionally stops coolwsd when the app is disabled (**Confirmed** [1][17][18]).
- **Nextcloud 29 and older cannot take the fix.** The fixed releases 26.4.303 and 26.4.502 both require Nextcloud 30 or later (**Confirmed** [15]; **Demonstrated** [43]). On those hosts the only fix is to upgrade Nextcloud or remove the app (**Confirmed** [1]).
- **The lab found two traps in the obvious checks.** `occ app:list` fails on a never-installed instance, and an unauthenticated probe of `/apps/richdocumentscode/appinfo/info.xml` returned 404 on the fixed container, where the app lived in `custom_apps/` (**Demonstrated** [44][45]; the cause is **Inferred** [24]).

Top recommendations

1. **Find every copy.** Check both app ids (`richdocumentscode` and `richdocumentscode_arm64`) in both `apps/` and `custom_apps/` on every Nextcloud host, and read the version from `appinfo/info.xml` directly; do not rely on `occ` alone or on a single URL path (**Confirmed** [20]; **Demonstrated** [44][45]; the two-id rule is **Inferred**).
2. **Upgrade or remove, never just disable.** Move to 26.4.303 at minimum and preferably to 26.4.502, which also stops coolwsd when the app is disabled. If the host is on Nextcloud 29 or older, upgrade Nextcloud first or remove the app with `occ app:remove` (**Confirmed** [1][17][21]).
3. **Treat an exposed host as possibly compromised.** KEV flags forensic triage for this CVE. Run `occ integrity:check-app richdocumentscode`, keep a copy of, then delete, any `EXTRA_FILE` it reports, search the access logs back to 10 September 2026, and rotate secrets the web server user could read (**Confirmed** [4][22][18]; the secret list is **Inferred**).
4. **Consider a standalone Collabora server.** Standalone Collabora Online is outside the advisory's affected set (**Confirmed** [1]); the built-in app's own summary calls it a server for local testing and non-production use (**Demonstrated** [43]).

5. **Do not send defenders to third-party "self-test" sites.** A Nextcloud forum moderator warned a poster of two such links about spam; use your own version checks (**Confirmed** [19]).

Scope and method

This study covers CVE-2026-110447 from the first logged attack (10 September 2026) to the lab run (4 November 2026). It is a lab-backed vulnerability study: what the flaw is, the public record, what the lab showed, how to find and fix it on real hosts, and the MITRE bindings. Every source was opened on 4 November 2026. Attack payloads seen in the victims' logs are described, never reproduced, and the lab never sent a request to `proxy.php`.

Grade	Meaning
Confirmed	A primary source opened for this study: the vendor's advisory, code, commits and releases, the CVE, NVD and CISA records, or a first-hand victim report on the vendor's tracker
Reported	A secondary source (press) or a single community report that no primary corroborates
Demonstrated	Shown in the TeamStarWolf lab run of 4 November 2026; the capture file is named
Inferred	Our reasoning from the sources, labelled as such

The lab ran on an isolated lab host with Docker. The vulnerable target was the public image `vulncheck/richdocumentscode:26.4.302`; the fixed target was the official `nextcloud:33.0.10-apache` image with the official 26.4.303 release tarball installed into it. Both containers published port 80 only on 127.0.0.1. The screenshots are renderings of the real command output with a neutral `lab$` prompt.

Part 1: the vulnerability in detail

Which app is vulnerable

Two Collabora pieces sit in a typical Nextcloud office setup. The `richdocuments` app ("Nextcloud Office") is the connector: it talks to a Collabora Online server somewhere. The `richdocumentscode` app ("Collabora Online - Built-in CODE Server") is one way to provide that server: it bundles the Collabora Online Development Edition as an AppImage and starts it on demand through its own `proxy.php`. CVE-2026-110447 is in `richdocumentscode` (**Confirmed** [2]). Its own app description, read from the shipped `info.xml` in the lab, calls it a built-in server "for local testing and non-production use" (**Demonstrated** [43]).

Nextcloud's own advisory repository lists no advisory for this CVE, and none of its advisories mentions `richdocumentscode` or `proxy.php`. The nearest, GHSA-x4hv-m8g6-5cj4 (CVE-2026-67400, 27 October 2026), is an unrelated low-severity WOPI information leak in `richdocuments` (**Confirmed** [7]). Do not conflate the two.

The flaw and its precondition

Collabora's advisory describes an unauthenticated OS command injection through `proxy.php` that runs a command as the web server user, affecting versions below 26.4.303 (**Confirmed** [1]). The attack only works while the built-in CODE server, `coolwsd`, is not running, for example on a container restart, an upgrade or after a crash (**Confirmed** [1]). That condition is not rare: the advisory itself lists an upgrade among the cases, and a crashed or never-started server stays down until a request arrives to launch it (**Inferred** from [1] and the launch logic in [9]).

The advisory adds four scoping statements (**Confirmed** [1]):

- Disabling the app is not sufficient; it must be upgraded to 26.4.303 or later, or removed.
- Users of end-of-life Nextcloud 29 or older should upgrade Nextcloud or remove the app.
- Standalone Collabora Online servers are not affected.
- This is not the same path as CVE-2025-66208, and that fix does not prevent it.

CVE-2025-66208, published by NVD on 3 December 2025, was a configuration-dependent OS command injection in the same proxy, reachable through an intermediate reverse proxy, fixed in 25.04.702 and also classed CWE-78 (**Confirmed** [8]). The same proxy has now produced two command-injection CVEs in under a year (**Confirmed** [1][8]).

Root cause

In 26.4.302, `startCoolwsd()` in `proxy.php` builds two request-derived options (**Confirmed** [9]):

- the remote font config URL, built from the `Host` header and a rewrite of the request URI, only when HTTPS is on; and
- the `lok_allow` host option, built from the `Host` header.

Both values pass through `escapeshellarg()`, which wraps them in single quotes. Both are then placed inside an outer double-quoted `bash -c "( ... )"` string (**Confirmed** [9]). Inside double quotes, single quotes are ordinary characters, so the outer shell still expands `$(...)` coming from the request path or the Host header (**Inferred** from [9] and [12]). The in-the-wild requests carried their payload in the URL path, which fits the request-URI route (**Inferred** from [18]).

The history shows how the code got there. At tag 25.4.202 the Host header was concatenated into the launch command with no escaping at all; by 26.4.104 it was `escapeshellarg()`-quoted, but still inside the same double-quoted `bash -c` string (**Confirmed** [10]).

The fix

Commit `6cc8dae54c92bae27d53c54b9898cf1123ca2066`, "tidy up how the coolwsd launch command is built", by Caolan McNamara, builds the inner command first and wraps the whole of it in `escapeshellarg()` before `bash -c` (**Confirmed** [11]). It was authored on 20 August 2026 and committed on 9 September 2026 (**Confirmed** [11]). The 26.4.302 to 26.4.303 range holds this one functional commit, changing only `proxy.php`, plus the version bump (**Confirmed** [12]). Neither the commit message nor the 26.4.303 changelog entry labels it a security fix, and the 26.4.303 release notes name only the bundled CODE tag `cp-26.04.3-3` (**Confirmed** [11][13][14]).

Later releases hardened the same code path (**Confirmed** [16][17]):

Release	Date	Change
26.4.402	24 Sep 2026	Font config URL built from `SCRIPT_NAME` (`34cbae9`); host options only from a well-formed Host header (`d062355`); coolwsd options passed to `proc_open` as separate arguments, with bash running only a fixed script (`06dd6aa`)
26.4.502	23 Oct 2026	Stop coolwsd when the app is disabled in Nextcloud (`813c171`, 20 Oct); coolwsd on the IPv4 loopback (`542a9d3`); host settings written by Nextcloud instead of taken from the request; pid file trusted only when `/proc/<pid>/comm` says coolwsd (`54e1e9c`); document fetches restricted to Nextcloud's own names (`68da60b`)

Versions and requirements

App release	Released	Bundled CODE	Status
26.4.302	31 Aug 2026	cp-26.04.3-2	Vulnerable
26.4.303	11 Sep 2026, 13:43 UTC	cp-26.04.3-3	Fixed
26.4.402	24 Sep 2026	cp-26.04.4-2	Fixed, hardened
26.4.502	23 Oct 2026	cp-26.04.5-2	Fixed, hardened, stops coolwsd when disabled

Sources: release dates from the GitHub releases list [13]; bundled CODE tags from the changelog, all four tags present in Collabora's `online.mirror` repository [14] (**Confirmed**). Each release ships an x86_64 tarball (`richdocumentscode.tar.gz`) and an arm64 tarball (**Confirmed** [13]).

`info.xml` at 26.4.302, 26.4.303 and 26.4.502 requires Nextcloud 30 to 35 on x86_64, and the 26.4.302 changelog says "Require Nextcloud 30 or later" (**Confirmed** [15]). A host on Nextcloud 29 or older therefore cannot install the fix (**Confirmed** [15], matching the advisory [1]).

Severity

Scorer	Score	Vector
CNA (MITRE)	CVSS 4.0 9.2 Critical	`CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N`
Collabora GHSA	CVSS 4.0 9.2 Critical, no CVSS 3 score	same vector
NVD (Primary)	CVSS 3.1 9.8 Critical	`AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`
CISA SSVC 2.0.3 (23 Oct 2026)	Exploitation active, Automatable yes, Technical Impact total	not applicable

Sources: [1][2][3] (**Confirmed**). Part of the gap between 9.2 and 9.8 is the CVSS 4.0 Attack Requirements metric, `AT:P`, which fits the not-running precondition; CVSS 3.1 has no such metric (**Inferred**). NVD's record is status Analyzed, with the CPE `collabora_online_-_built-in_code_server` (target Nextcloud) below 26.4.303, last modified 30 October 2026 (**Confirmed** [3]).

Part 2: the timeline

Date (2026 unless noted)	Event	Grade	Source
3 Dec 2025	NVD publishes CVE-2025-66208, the earlier, configuration-dependent command injection in the same proxy	Confirmed	[8]
20 Aug	Fix commit `6cc8dae` authored	Confirmed	[11]
31 Aug	26.4.302 released (still vulnerable)	Confirmed	[13]
9 Sep	Fix commit committed	Confirmed	[11]
10 Sep, 19:51 +0200	First logged exploitation: a request from 139.28.18.122 to `/apps/richdocumentscode/proxy.php?status` on a server running 26.4.302	Confirmed	[18]
11 Sep, 09:56 +0200	A second server hit from the same address	Confirmed	[18]
11 Sep, 13:43 UTC	26.4.303 released, with no security note	Confirmed	[13]
11 Sep, 14:53 UTC	The victim administrator opens issue #354 on the `richdocumentscode` tracker, about an hour after the fixed release	Confirmed	[18]
14 Sep	A second source, 89.38.98.50, hits a host already on 26.4.303, and `ps` shows the AppImage with an attacker-shaped font-config option; mmeeks, writing for the vendor ("We'll provide more updates"), says the issue affects only the Development Edition in Built-in CODE Server mode; Collabora member timar says he believes 26.4.303 fixes it	Confirmed	[18]
18 Sep	A Collabora developer replies that the `ps` output should be harmless after the upgrade and that lingering `shx*.php` files must be removed	Confirmed	[18]
24 Sep	26.4.402 released with launch-path hardening	Confirmed	[13][16]
29 Sep	An issue commenter claims threat actors and ransomware operators began abusing the flaw	Reported	[18][27]
3 Oct	A community member (not staff) opens the forum thread "To Collabora Built-in User: Update ASAP"	Reported	[19]
14 Oct, 02:27 UTC	MITRE reserves and publishes CVE-2026-110447 (CVE request form)	Confirmed	[2]
14 Oct, 03:17 UTC	NVD publishes the CVE	Confirmed	[3]

Date (2026 unless noted)	Event	Grade	Source
14 Oct, 03:30 UTC	GitHub's unreviewed global advisory GHSA-f97p-r72q-64h2 appears	Confirmed	[6]
14 Oct, 07:36 UTC	Collabora publishes GHSA-g3vx-3m76-fghh (by caolanm), crediting GitHub user wwwshellcodeit; caolanm closes issue #354 with the advisory link at 08:32 UTC	Confirmed	[1][18]
14 Oct	The Hacker News reports; no actor, no ransomware link, no scan counts	Reported	[28]
15 Oct	BleepingComputer reports Collabora's explanation for the delay and Nextcloud's comments	Reported	[27]
16 Oct	ModSecurity rule 949110 blocks two attempts for one user (posted 27 Oct)	Reported	[18]
16 Oct	A forum user's integrity check flags `EXTRA_FILE Nx_33143.php` in `richdocumentscode` after upgrading to Nextcloud 35.0.2	Reported	[19]
17 Oct	A forum moderator warns a poster of two third-party self-test links about spam	Confirmed	[19]
20 Oct	Commit `813c171`, stop coolwsd when the app is disabled	Confirmed	[17]
23 Oct	CISA adds the CVE to KEV (due 26 Oct) and records SSVC; 26.4.502 released the same day	Confirmed	[4][2][13]
26 Oct	Forum post: the fixed app needs Nextcloud 30 or later	Reported	[19]
30 Oct	A user reports the attack works on a disabled, not-updated app; Collabora's caolanm confirms that is in the advisory and that 26.4.502 includes `813c171`; NVD last modifies its record	Confirmed	[18][3]
4 Nov	TeamStarWolf lab run of 26.4.302 against 26.4.303	Demonstrated	[43] to [47]

Two intervals frame the defender's problem. The first logged attack predates the fixed release by under a day, and the advisory followed the fix by 33 days (**Confirmed** [13][18][1]). For a month, an administrator reading release notes had no signal that 26.4.303 mattered.

Part 3: exploitation in the wild

Who reported it

Exploitation was reported by victim administrators on issue #354, from several independent installations: one noticed through failed sudo mails, another through Nextcloud's integrity check (**Confirmed** [18]). No vendor, CERT or research firm attributes the activity, and no threat actor is named in any primary source opened for this study (**Confirmed** [18][1][3][4]). The CVE record and NVD state the app allows remote code execution, "as exploited in the wild in September and October 2026" (**Confirmed** [2][3]).

What the attackers did

From the victims' reports on issue #354 (**Confirmed** as first-hand reports [18]):

- Unauthenticated GET requests ending in `/apps/richdocumentscode/proxy.php?status`, with `%2e%2e` traversal, `$(...)` substitution, `${IFS}` in place of spaces, and base64 payloads piped to `sh`.
- One-line PHP web shells dropped in the app folder, named like `shrf4645.php` and `shxa35d0.php`, that run `shell_exec` on a GET parameter.
- Callbacks to webhook.site carrying `uname -a` output.
- On one host, the shell was used to search for `*.kdbx`, `wallet.dat`, `keystore.json` and other password-manager and coin-wallet artifacts.
- No archive or exfiltration commands seen in the reviewed requests.
- A recovered sample with SHA-256 `4b9fbd0663fbfd6028fc216ed18e0d6ef3ae498a7fdc97083e4b0ce3cec40562`.

A forum user later found a differently named backdoor, `Nx_33143.php`, through the integrity check (**Reported**, single user [19]). The Hacker News notes that none of the reports show root access (**Reported** [28]).

Ransomware and scale

Ransomware use is unverified. One issue commenter claimed on 29 September that threat actors and ransomware operators had begun abusing the flaw; BleepingComputer could not confirm it, and KEV lists ransomware use as Unknown (**Reported** [18][27]; KEV **Confirmed** [4]). No primary source gives a count of affected or exposed servers: the advisory, NVD, KEV and issue #354 are all silent, and neither press report gives a number (**Confirmed** [1][3][4][18]; press **Reported** [27][28]).

What the vendors said

BleepingComputer reports that Collabora attributed the advisory delay mainly to GitHub CVE-processing backlogs and named Docker, RPM and DEB packages and Nextcloud All-in-One as unaffected, and that Nextcloud said Collabora reported the flaw in mid-September and that it had not seen widespread exploitation (**Reported** [27]). The community forum thread lists the same unaffected setups: `richdocuments` without the built-in app, Collabora from Docker or a distribution package, and hosted Collabora (**Reported** [19]).

Part 4: what the lab showed

The lab question was narrow: can a defender tell a vulnerable host from a fixed one without touching the vulnerable code path, and does the fix look the way the advisory says? Every step only read state. No request was sent to `proxy.php`.

Setup

The run began at 04:57:16 UTC on 4 November 2026 (**Demonstrated** [43]). The vulnerable target was `vulncheck/richdocumentscode:26.4.302` (digest `sha256:e3549dee2c81...8898`); the fixed target was `nextcloud:33.0.10-apache` (digest `sha256:53797c68b5b5...9f28`) with the official 26.4.303 release tarball, 283,792,403 bytes, SHA-256 `e288f29ba5c3...61a7`, copied into `custom_apps/` and enabled (**Demonstrated** [43]). The tarball was reviewed in quarantine first and held only vendor app files; its `info.xml` declares version 26.4.303, Nextcloud 30 to 35, x86_64 (**Demonstrated** [43]).

Both containers exposed 80/tcp published only on 127.0.0.1, port 8081 for the vulnerable build and 8082 for the fixed one; the vulnerable container sat on an `--internal` Docker network plus the default bridge for the loopback mapping (**Demonstrated** [43]):

```
{"80/tcp":{}} {"80/tcp":[{"HostIp":"127.0.0.1","HostPort":"8081"}]}
```



Test: telling vulnerable from fixed

`status.php` gives the Nextcloud core version without login: `"versionstring":"30.0.17"` with `"installed":false` on the vulnerable container and `"versionstring":"33.0.10"` with `"installed":true` on the fixed one (**Demonstrated** [44]). Reading `info.xml` inside each container gives the app version (**Demonstrated** [44]):

```
/var/www/html/apps/richdocumentscode/appinfo/info.xml:<version>26.4.302</version>
/var/www/html/custom_apps/richdocumentscode/appinfo/info.xml:<version>26.4.303</version>
```

A `sort -V` comparison against the 26.4.303 floor produced the differing observable (**Demonstrated** [44]):

```
nc-vuln richdocumentscode 26.4.302 VULNERABLE (< 26.4.303, CVE-2026-110447)
nc-fixed richdocumentscode 26.4.303 FIXED (>= 26.4.303)
```

This contradicted the lab plan in one place. The plan expected the vulnerable image to be an installed Nextcloud, but `occ status` reported `installed: false`, so `occ app:list` failed on that side with `There are no commands defined in the "app" namespace.` (**Demonstrated** [43][44]). Only the filesystem `info.xml` read worked on both sides. The lesson for real hosts: read `info.xml` directly; `occ` answers only on an installed instance.

The test capture is not shown as a screenshot: only the setup, exposure, mitigation and cleanup captures are, and the lines quoted above are its whole result.

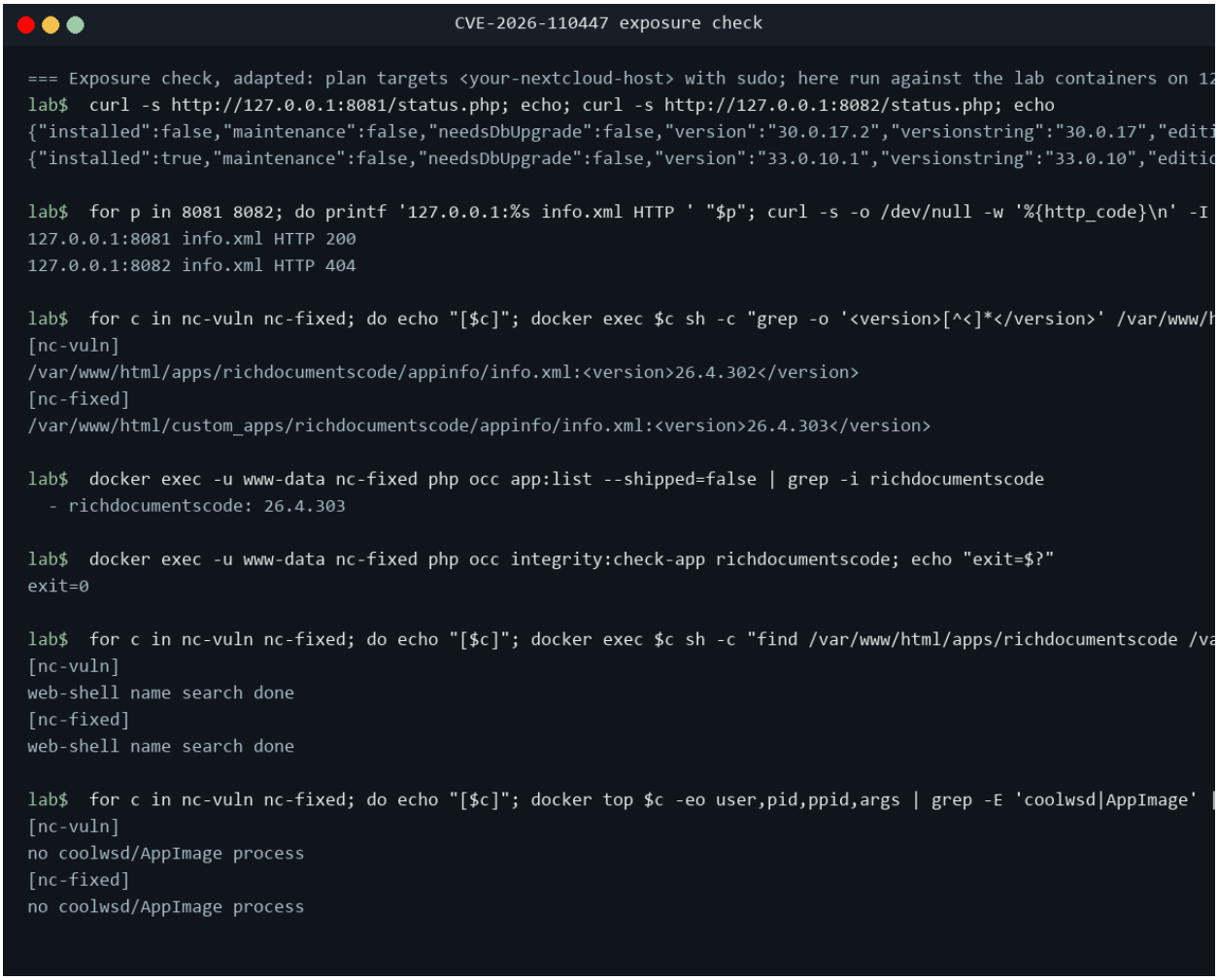
Exposure check: the remote probe trap

A remote, unauthenticated HEAD request for the app's `info.xml` at the `/apps/` path gave different answers for a reason unrelated to the fix (**Demonstrated** [45]):

```
127.0.0.1:8081 info.xml HTTP 200
127.0.0.1:8082 info.xml HTTP 404
```

The vulnerable build keeps the app in `apps/`; the fixed container, like the official Docker image, keeps App Store apps in `custom_apps/` (**Demonstrated** [44]; **Confirmed** [24]). A 404 at `/apps/` is therefore not proof the app is absent. A remote probe must also try `/custom_apps/richdocumentscode/appinfo/info.xml`, and a 200 at either path means the app's version is readable without login (**Inferred** from [24] and [45]).

On the fixed container, `occ app:list --shipped=false` listed `- richdocumentscode: 26.4.303`, and `occ integrity:check-app richdocumentscode` printed nothing and exited 0, which is what a pass looks like (**Demonstrated** [45]; **Confirmed** [22]). Neither container ran a `coolwsd` or AppImage process: the bundled server was not running, which is the state the advisory calls exploitable (**Demonstrated** [45]). Exploitability itself was not exercised.



Mitigation: the fix read from the running builds

The launch line differs exactly as the fix commit says (**Demonstrated** [46]). On the vulnerable build, line 105 builds `$launchCmd` as a double-quoted `bash -c "( ... )"` string with the options interpolated inside it. On the fixed build, line 107 reads:

```
107:    $launchCmd = "bash -c " . escapeshellarg($innerCmd);
```

A `diff` of the two files shows only that hunk plus the expected coolwsd hash, `$expVer`, changing from `cc5614c67e` to `7ddebab0ef` (**Demonstrated** [46]). In the 26.4.303 source, the Host header value and the HTTPS font-config URL each still pass through `escapeshellarg()` before going into `$innerCmd`, which is then escaped again as a whole (**Demonstrated** [43]). That is the root cause closed: the individually quoted values no longer sit inside a string the outer shell re-parses (**Inferred** from [43], [46] and [12]).

One side effect is useful for responders. `proxy.php` compares the running coolwsd's hash with `$expVer` and logs `Old server found, restarting.` when they differ (**Demonstrated** [43]). After an upgrade, that line in the PHP error log marks the first relaunch under the new code (**Inferred**).

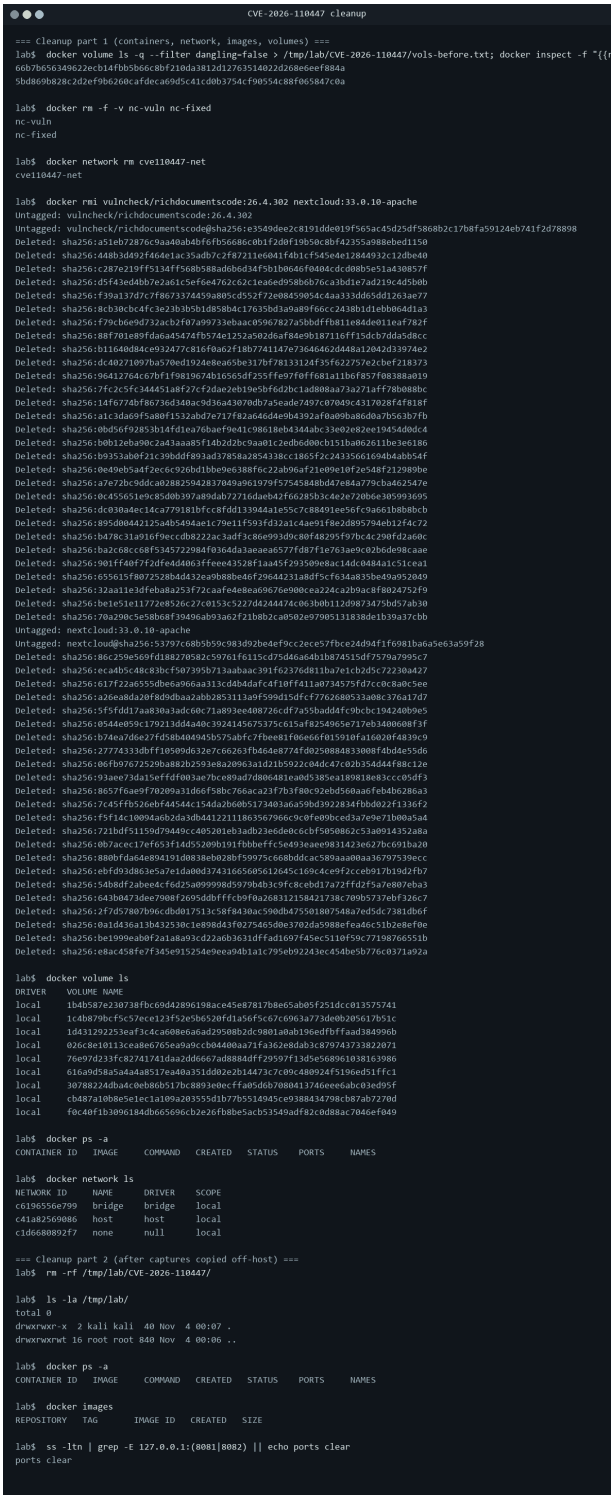
The same capture checked detection silence: version scanning produced `nc-vuln proxy.php requests: 0` and `nc-fixed proxy.php requests: 0`, and the only access-log line from the test was a `GET /status.php`

returning 200 (**Demonstrated** [46][44]). A web rule keyed on `proxy.php` therefore stays quiet during your own version checks. No positive-case detection test was run, because that would need exploit traffic.



Cleanup

Both containers were removed with their two volumes, the internal network and both images were deleted, the working folder `/tmp/lab/CVE-2026-110447/` was removed, `docker ps -a` and `docker images` came back empty, and the final check printed `ports clear` for 127.0.0.1:8081 and 8082 (**Demonstrated** [47]).


CVE-2026-110447 cleanup
=== Cleanup part 1 (containers, network, images, volumes) ===
lab$ docker volume ls -q --filter dangling=false > /tmp/lab/CVE-2026-110447/vols-before.txt; docker inspect -f "{{
66b7b65634962 2ecb14fbb5b66c8bf210da3812d1276351402 2d268e6eef884a
5bd869b828c2d2ef9b6260cafdeca69d5c41cd0b3754cf90554c88f065847c0a
lab$ docker rm -f -v nc-vuln nc-fixed
nc-vuln
nc-fixed
lab$ docker network rm cve110447-net
cve110447-net
lab$ docker rmi vulncheck/richdocumentscode:26.4.302 nextcloud:33.0.10-apache
Untagged: vulncheck/richdocumentscode:26.4.302
Untagged: vulncheck/richdocumentscode@sha256:e3549dee2c8191dde019f565ac45d25df5868b2c17b8fa59124eb741f2d78898
Deleted: sha256:a51eb72876c9aa40ab4bf6fb56686c0b1f2d0f19b50c8bf42355a988ebed1150
Deleted: sha256:448b3d492f464e1ac35adb7c2f87211e6041f4b1cf545e4e12844932c12dbe40
Deleted: sha256:c287e219ff5134ff568b588ad6b6d34f5b1b0646f0404cdcd08b5e51a430857f
Deleted: sha256:d5f43ed4bb7e2a61c5ef6e4762c62c1ea6ed958b6b76ca3bd1e7ad219c4d5b0b
Deleted: sha256:f39a137d7c7f86733744594a805cd552f72e08459054c4aa333dd65dd1263ae77
Deleted: sha256:8cb30cbc4fc3e23b3b5b1d858b4c17635bd3a9a89f66cc2438b1d1ebb064d1a3
Deleted: sha256:f79cb6e9d732acb3f07a09733eb3aac05967827a5bbdffb811e84de011eaf782f
Deleted: sha256:88f701e80fda6a45474fb574e1252a502d6af84e9b187116ff15dcb7dda5d8cc
Deleted: sha256:b11640d84ce932477c816f0a62f18b7741147e73646462d448a12042d33974e2
Deleted: sha256:dc40271097ba570ed1924e8ea65be317bf78133124f35f622757e2cbef218373
Deleted: sha256:96412764c67bf1f9819674b16565df255ffe97f0ff681a11b6f857f08388a019
Deleted: sha256:7fc2c5fc344451a8f27cf2dae2eb19e5bf6d2bc1ad808aa73a271aff78b088bc
Deleted: sha256:14f674bf86736d340ac9d36a43070db7a5eade7497c07049c4317028f4f818f
Deleted: sha256:a1c3da69f5a80f1532abd7e717f82a646d4e9b4392af0a09ba86d0a7b563b7fb
Deleted: sha256:0bd56f92853b14fd1ea76baef9e41c98618eb4344abc33e02e82ee19454d0dc4
Deleted: sha256:b0b12eba90c2a43aaa85f14b2d2bc9aa01c2edb6d00cb151ba062611be3e6186
Deleted: sha256:b9353ab0f21c39bddf893ad37858a2854338cc1865f2c24335661694b4abb54f
Deleted: sha256:0e49eb5a4f2ec6c926bd1bbe9e6388f6c22ab96af21e09e10f2e548f212989be
Deleted: sha256:a7e72bc9ddca028825942837049a961979f57545848bd47e84a779cba462547e
Deleted: sha256:0c455651e9c85d0b397a89dab72716daeb42f66285b3c4e2e720b6e305993695
Deleted: sha256:dc030a4ec14ca779181bfcc8fdd133944a1e55c7c88491ee56fc9a661b8b8bcb
Deleted: sha256:895d00442125a4b5494ae1c79e11f593fd32a1c4ae91f8e2d895794eb12f4c72
Deleted: sha256:b478c31a916f9eccdb8222ac3adf3c86e993d9c80f48295f97bc4c290fd2a60c
Deleted: sha256:ba2c68cc68f5345722984f0364da3aeaea6577fd87f1e763ae9c02b6de98caae
Deleted: sha256:901ff40f2f2dfe4d4063ffeee43528f1aa45f293509e8ac14dc0484a1c51cea1
Deleted: sha256:655615f8072528b4d432ea9b88be46f29644231a8df5cf634a835be49a952049
Deleted: sha256:32aa11e3dfeba8a253f72caafe4e8ea69676e900cea224ca2b9ac8f8024752f9
Deleted: sha256:be1e51e11772e8526c27c0153c5227d4244474c063b0b112d98734 75bd57ab30
Deleted: sha256:70a290c5e58b68f39496ab93a62f21b8b2ca0502e97905131838de1b39a37cbb
Untagged: nextcloud:33.0.10-apache
Untagged: nextcloud@sha256:53797c68b5b59c983d92be4ef9cc2ece57fbce24d94f1fe981ba6a5e63a59f28
Deleted: sha256:86c259e569fd188270582c59761f6115cd75d46a64b1b874515df7579a7995c7
Deleted: sha256:eca4b5c48c83bcf507395b713aabaac391f62376d811ba7e1cb2d5c72230a427
Deleted: sha256:617f22a6555dbe6a966aa313cd4b4dafc4f10ff411a0734575fd7cc0c8a0c5ee
Deleted: sha256:a26ea8da20f8d9dbaa2abb2853113a9f599d15dfcf7762680533a08c376a17d7
Deleted: sha256:5f5fdd17aa830a3adc60c71a893ee408726cdf7a55baddd4fc9bcbc194240b9e5
Deleted: sha256:0544e059c179213dd4a40c39241456753 75c615af8254965e717eb3400608f3f
Deleted: sha256:b74ea7d6e27fd58b404945b575abfc7fbee81f06e66f015910fa16020f4839c9
Deleted: sha256:27774333dbff10509d632e7c66263fb464e8774fd025088483300 8f4bd4e55d6
Deleted: sha256:06fb97672529ba882b2593e8a20963a1d21b5922c04dc47c02b354d44f88c12e
Deleted: sha256:93aee73da15effdf003ae7bce89ad7d806481ea0d5385ea189818e83ccc05df3
Deleted: sha256:8657f6ae9f70209a31d66f58bc766aca23f7b3f80c92ebd560aa6feb4b6286a3
Deleted: sha256:7c45ffb526ebf44544c154da2b60b5173403a6a59bd3922834fbbd022f1336f2
Deleted: sha256:f5f14c10094a6b2da3db4412211186356 7966c9c0fe09bced3a7e9e71b00a5a4
Deleted: sha256:721bdf51159d79449cc405201eb3adb23e6de0c6cbf5050862c53a0914352a8a
Deleted: sha256:0b7acec17ef653f14d55209b191fbbbeffc5e493eaee9831423e627bc691ba20
Deleted: sha256:880bfda64e894191d0838eb028bf59975c668bddcac589aaa00aa36797539ecc
Deleted: sha256:ebfd93d863e5a7e1da00d3743166560 5612645c169c4ce9f2cceb917b19d2fb7
Deleted: sha256:54b8df2abee4cf6d25a099998d5979b4b3c9fc8cebd17a72ffd2f5a7e807eba3
Deleted: sha256:643b0473dee7908f2695ddbfffcb9f0a26831215842173 8c709b5737ebf326c7
Deleted: sha256:2f7d57807b96cdbd017513c58f8430ac590db475501807548a7ed5dc7381db6f
Deleted: sha256:0a1d436a13b432530c1e898d43f0275465d0e3702da5988efea46c51b2e8ef0e
Deleted: sha256:be1999eab0f2a1a8a93cd22a6b3631dffad1607f45ec5110f59c7198766551b
Deleted: sha256:e8ac458fe7f345e915254e9eea94b1a1c795eb92243ec454be5b776c0371a92a
lab$ docker volume ls
DRIVER VOLUME NAME
local 1b4b587e230738fbc69d42896198ace45e87817b8e65ab05f251dcc013575741
local 1c4b879bcf5c57ece123f52e5b6520fd1a56f5c67c6963a773de0b205617b51c
local 1d431292253eaf3c4ca608e6a6ad2950 8b2dc9801a0ab196edfbffaad38499 6b
local 026c8e10113cea8e6765ea9a9ccb04400aa71fa362e8dab3c879743733822071
local 76e97d233fc82741741daa2dd6667ad8884dff29597f13d5e56896103816 3986
local 616a9d58a5a4a4a8517ea40a351dd02e2b14473c7c09c480924f5196ed51ffc1
local 3078822 4dba4c0eb86b517bc8893e0ecffa05d6b7080413746eee6abc03ed95f
local cb487a10b8e5e1ec1a109a203555d1b77b5514945ce9388434798cb87ab7270d
local f0c40f1b3096184db665696cb2e26fb8be5acb53549adf82c0d88ac7046ef049
lab$ docker ps -a
CONTAINER ID IMAGE COMMAND CREATED STATUS PORTS NAMES
lab$ docker network ls
NETWORK ID NAME DRIVER SCOPE
c6196556e799 bridge bridge local
c41a82569086 host host local
c1d6680892f7 none null local
=== Cleanup part 2 (after captures copied off-host) ===
lab$ rm -rf /tmp/lab/CVE-2026-110447/
lab$ ls -la /tmp/lab/
total 0
drwxrwxr-x 2 kali kali 40 Nov 4 00:07 .
drwxrwxrwt 16 root root 840 Nov 4 00:06 ..
lab$ docker ps -a
CONTAINER ID IMAGE COMMAND CREATED STATUS PORTS NAMES
lab$ docker images
REPOSITORY TAG IMAGE ID CREATED SIZE
lab$ ss -ltn | grep -E 127.0.0.1:(8081|8082) || echo ports clear
ports clear

Part 5: how to find and fix it on real hosts

Run these as the web server user from the Nextcloud root. The vendor README names that user: `www-data` on Debian and Ubuntu, `wwwrun` on SUSE, `apache` on Red Hat and Fedora, `http` on Arch (**Confirmed** [20]). The README also notes that `richdocumentscode` is x86_64 only and ARM64 hosts use the app id `richdocumentscode_arm64` (**Confirmed** [20]). The advisory names only `richdocumentscode`, and whether the arm64 26.4.302 build carries the same `proxy.php` was not checked; check both ids (**Inferred**).

Step 1: find the app and read its version

```
# installed instance: list non-shipped apps and their versions
sudo -E -u www-data php occ app:list --shipped false
sudo -E -u www-data php occ app:getpath richdocumentscode

# works even where occ cannot (never-installed or broken instance)
grep -o '<version>[^<]*</version>' \
  apps/richdocumentscode/appinfo/info.xml \
  custom_apps/richdocumentscode/appinfo/info.xml \
  apps/richdocumentscode_arm64/appinfo/info.xml \
  custom_apps/richdocumentscode_arm64/appinfo/info.xml 2>/dev/null
```

The `occ` commands are from Nextcloud's documentation (**Confirmed** [21]); the filesystem read is the one that worked on both lab containers (**Demonstrated** [44]). Remotely and read-only, `curl -s https://<host>/status.php` gives the core version, and a HEAD request for `appinfo/info.xml` under both `/apps/richdocumentscode/` and `/custom_apps/richdocumentscode/` shows whether the app is reachable (**Demonstrated** [44][45]; the `/custom_apps/` path is **Inferred** [24]).

- **What vulnerable looks like:** any version below `26.4.303`, enabled or disabled.
- **What fixed looks like:** `26.4.303` or later; `26.4.502` or later also stops coolwsd when the app is disabled.

Step 2: upgrade, or remove

```
sudo -u www-data php -d memory_limit=512M ./occ app:update --all
# or one app, with a preview first
sudo -E -u www-data php occ app:update --showonly
sudo -E -u www-data php occ app:update richdocumentscode
```

The `--all` form is the vendor README's (**Confirmed** [20]); `--showonly` and the single-app form are from the `occ` documentation (**Confirmed** [21]). If you cannot upgrade, including every host on Nextcloud 29 or older, remove the app:

```
sudo -E -u www-data php occ app:remove richdocumentscode
```

`occ app:remove` disables and removes an app; `occ app:disable` alone is not a fix (**Confirmed** [21][1]). After removal, point the Nextcloud Office connector at a standalone Collabora Online server, which is outside the affected set (**Confirmed** [1]).

Package formats

Install type	How to run occ	Note
Official Docker image	`docker exec -it --user www-data CONTAINER_ID php occ ...` or `docker compose exec --user www-data app php occ ...`	App Store apps live in `/var/www/html/custom_apps` (**Confirmed** [24]); the lab's fixed container used this layout (**Demonstrated** [43])
Snap	`sudo nextcloud.occ ...`	**Confirmed** [25]
All-in-One	in the AIO Nextcloud container	AIO ships Collabora as its own container, `nextcloud-aio-collabora`, which is a standalone deployment outside the advisory's set unless `richdocumentscode` was also installed (**Inferred** from [26] and [1])
Tarball or distribution package	from the Nextcloud root as the web server user	**Confirmed** [20][21]

Step 3: confirm the fix and look for leftovers

```
sudo -E -u www-data php occ integrity:check-app richdocumentscode
```

A pass prints nothing; files added to the app folder are reported as `EXTRA_FILE` (**Confirmed** [22][23]; **Demonstrated** [45]). Upgrading does not remove a web shell already planted: a Collabora developer told victims that lingering `shx*.php` files must be removed (**Confirmed** [18]). Delete any `shx*.php`, `shrf*.php`, `Nx_*.php` or other `EXTRA_FILE`, keep a copy for the investigation first, and rotate the secrets the web server user could read, such as the database password in Nextcloud's config and any API tokens on the host (**Inferred**; the file names are **Confirmed** [18] and **Reported** [19]).

Logs to keep for triage are `nextcloud.log`, the container logs, and `/tmp/coolwsd.*/coolwsd.log` (**Confirmed** [20]).

Step 4: follow the KEV forensic triage

KEV marks this entry `forensicTriage: Yes`, and its required action cites BOD 26-04 and its Forensics Triage Requirements (**Confirmed** [4]). The BOD 26-04 implementation guidance sets six steps, and defers to KEV-specific triage steps where an entry gives them (**Confirmed** [5]). Mapped to this CVE:

BOD 26-04 step	For CVE-2026-110447
Scoping	Every Nextcloud host with either app id, in either folder, enabled or disabled
Preserve and Collect Evidence	Access logs from 10 September 2026, `nextcloud.log`, coolwsd logs, a copy of the app folder
Critical Patching and Stabilization	Upgrade to 26.4.303 or later (26.4.502 preferred), or remove the app
Contain and Control	Block the known source addresses and outbound traffic to webhook.site; take an affected host off the internet until cleaned
Triage Analysis	Integrity check, web-shell file search, access-log search for the patterns in Part 6

BOD 26-04 step	For CVE-2026-110447
Escalation Decision	Escalate when an `EXTRA_FILE` or a matching request is found, since the web server user's secrets are then exposed

The step names are **Confirmed** [5]; the right-hand column is our application of them (**Inferred**, built from [1][18][20][22]).

Part 6: detection

From the logged attacks, described only (**Confirmed** [18]):

- **Web access log:** unauthenticated GET requests ending in `/apps/richdocumentscode/proxy.php?status` whose path carries `$(`, `${IFS}`, `base64` and `|sh`, often with `%2e%2e`. Search from 10 September 2026 onward.
- **Network:** requests from 139.28.18.122 and 89.38.98.50; outbound HTTPS from the Nextcloud host to webhook.site.
- **Process:** the Collabora AppImage or `coolwsd` running as the web server user with shell metacharacters in `--o:remote_font_config.url` or `net.lok_allow.host`. The 14 September report shows this on a host already upgraded to 26.4.303, and the vendor replied that it should be harmless there, so read it alongside the version (**Confirmed** [18]).
- **File:** new PHP files in the app root, and `EXTRA_FILE` results from the integrity check (**Confirmed** [18][22]; `Nx_` naming **Reported** [19]).
- **WAF:** ModSecurity CRS rule 949110 (Inbound Anomaly Score Exceeded) returned 403 to two attempts for one user on 16 October (**Reported** [18]).

The lab plan proposes four rules: a Wazuh access-log rule on `proxy.php` plus those tokens, Wazuh syscheck in realtime on both app folders, an auditd `execve` rule for the web server user (euid 33) under `apache2` or `php-fpm`, and a Sigma web server rule on the same URI and tokens (**Inferred** [42]). None was tested against positive traffic. The lab did show that version scanning leaves no `proxy.php` line in the access log, so a rule keyed on it would stay silent (**Demonstrated** [46]; the rule behaviour is **Inferred**).

Part 7: the vulnerability-management view

This CVE is a lesson in signals that arrive in the wrong order.

- **The fix came before the warning.** A program that triages by advisory saw nothing from 11 September to 14 October, while victims were posting web shells on a public issue. A silent patch to an internet-facing component that runs shell commands is a reason to update promptly, label or no label.
- **The CVE arrived with KEV close behind.** The CVE was published on 14 October, and KEV followed nine days later with a three-day due date and a forensic triage flag (**Confirmed** [2][4]). With a first logged attack a month before the CVE, the right question by then was "was I hit?", not "am I vulnerable?" (**Inferred** from [2][18]).
- **Two severity numbers, one decision.** CVSS 4.0 says 9.2 with the precondition recorded as `AT:P`; CVSS 3.1 says 9.8 (**Confirmed** [2][3]). The precondition covers routine events such as restarts and upgrades

(**Confirmed** [1]), so the lower number should not slow anyone down.

- **"Disabled" is not "fixed".** The advisory and the 30 October report both say a disabled app that has not been updated is still exploitable; only upgrading to 26.4.303 or later, or removing the app, closes it (**Confirmed** [1][18]). Asset inventories that record only enabled apps undercount exposure.
- **End-of-life core blocks the fix.** Hosts on Nextcloud 29 or older cannot install the fixed releases checked, 26.4.303 and 26.4.502 (**Confirmed** [15]). This is the case where an unmaintained platform turns a patch into a removal.

The library's CVE Reference covers CVSS 4.0, and the Vulnerability Prioritization Reference covers how SSVC and KEV outrank a raw score; this case is a compact example of why both belong in a triage record.

Overstated and understated

- **Overstated:** the ransomware link, which rests on one unverified issue comment; KEV lists ransomware use as Unknown (**Reported** [18][27]; **Confirmed** [4]).
- **Understated:** exposure from disabled but not-updated copies, and from hosts patched after a web shell was already planted (**Confirmed** [1][18]).

Part 8: MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0, CWE, CAPEC and D3FEND. Every ATT&CK id was checked against its live page and the library's `data/attack/technique_profiles.jsonl` on 4 November 2026 [29] to [34]; CAPEC and D3FEND ids against their live pages and the library's generated pages [37] to [40]. The record is Enterprise only; there is no ICS or Mobile mapping.

ATT&CK Enterprise techniques

Tactic names follow ATT&CK v20.0, where the former Defense Evasion tactic is split into Stealth and Defense Impairment.

Id	Name	Tactic (v20.0)	Where it appears in the record	Source
T1190	Exploit Public-Facing Application	Initial Access	Unauthenticated requests to `proxy.php` on internet-facing Nextcloud, from 10 Sep 2026; KEV entry 23 Oct 2026	[18][4][3][29]
T1059.004	Unix Shell	Execution	Decoded command piped to `sh` in the logged requests (issue #354, 10 Sep 2026)	[18][30]
T1505.003	Web Shell	Persistence	`shrf*`/`shx*` PHP shells (issue #354, 10 and 11 Sep 2026); `Nx_33143.php` (forum, 16 Oct 2026)	[18][19][31]
T1027	Obfuscated Files or Information	Stealth	Base64-encoded command in the request path (issue #354, 10 Sep 2026)	[18][32]
T1140	Deobfuscate/Decode Files or Information	Stealth	The encoded command decoded on the host before running (issue #354, 10 Sep 2026)	[18][33]
T1082	System Information Discovery	Discovery	`uname -a` output sent in the webhook.site callback (issue #354, 10 Sep 2026)	[18][34]

Considered and left out of the table (**Inferred**): T1071.001 Web Protocols for the webhook.site callback, and T1552.001 Credentials In Files and T1083 File and Directory Discovery, which the lab plan lists as likely post-exploitation steps [35][42]. The victims' report of searches for password databases and wallets points in that direction, but no opened record pins a technique id to it.

Groups, software and campaigns

No ATT&CK group, software or campaign object is attributed to this exploitation in any opened source, and no threat actor is named (**Confirmed** [1][18]). There is nothing to bind under `/mitre/groups/`, `/mitre/software/` or `/mitre/campaigns/`.

CWE and CAPEC

Id	Name	Basis	Library page
CWE-78	Improper Neutralization of Special Elements used in an OS Command	Listed by the advisory, the CVE record, NVD and KEV [1][2][3][4][36]	CWE Reference (no per-CWE page)
CAPEC-88	OS Command Injection	Related to CWE-78 in the library's `data/weaknesses/cwe.jsonl` [37]	CAPEC-88
CAPEC-650	Upload a Web Shell to a Web Server	Mapped to T1505.003 in the library's `data/weaknesses/capec.jsonl` [38]	CAPEC-650

The library also lists CAPEC-6, 15, 43 and 108 under CWE-78 (**Confirmed** [37]); CAPEC-88 is the direct fit for this flaw.

D3FEND countermeasures

D3FEND technique	Tactic	Library mapping	Where it fits
File Integrity Monitoring (D3-FIM)	Detect	T1505.003	`occ integrity:check-app` and syscheck on the app folders
Process Spawn Analysis (D3-PSA)	Detect	T1505.003	The web server user spawning a shell
File Eviction (D3-FEV)	Evict	T1505.003	Deleting the dropped web shells
Inbound Traffic Filtering (D3-ITF)	Isolate	T1190	WAF blocks such as CRS 949110
Application Protocol Command Analysis (D3-APCA)	Detect	T1190	Access-log matching on `proxy.php` and shell tokens
Software Update (D3-SU)	Harden	not mapped to these techniques	The vendor fix (**Inferred** binding) [40]
Credential Rotation (D3-CRO)	Harden	not mapped to these techniques	Rotating secrets the web server user could read (**Inferred** binding)

The first five mappings are the library's own D3FEND data (**Confirmed** [39]); the last two are our reasoning.

Navigator layer

The study's six techniques are saved as an ATT&CK Navigator layer, navigator/library-layers/nextcloud-richdocumentscode-cve-2026-110447.json, listed on the Navigator layers page beside the other hand-authored layers in that folder [41]. It is pinned to ATT&CK v20 and scores 100 for T1190, the exploitation itself, and 75 for the five post-exploitation techniques from the victims' reports. Each entry's comment names the source numbers in the table above.

Cross-cutting themes

- **Convenience components carry production risk.** The built-in server describes itself as for local testing and non-production use, yet it ran on internet-facing servers at several independent installations (**Demonstrated** [43]; **Confirmed** [18]). Any app that bundles a server and launches it through a shell inherits the attack surface of both.
- **Escaping is about the whole command, not each value.** Each request value was quoted, and the bug survived because the quoted values were nested inside another shell string. The durable fix, which 26.4.402 reached, is to stop building the shell command from request values and pass each option as its own argument to a fixed script (**Confirmed** [16]).
- **Silent fixes shift the burden to the defender.** An untitled fix with no advisory for a month meant only those who updated by habit were protected in time. Update cadence for internet-facing apps is a security control in its own right.
- **Victims were the early-warning system.** The first public signal came from an administrator's GitHub issue, not a vendor bulletin or a CERT (**Confirmed** [18]). Watching the issue trackers of the components you expose is cheap intelligence.
- **Checks need to match the deployment layout.** The lab's two traps, `occ` on an uninstalled instance and the `apps/` versus `custom_apps/` path, are the kind of gap that turns a correct check into a false "not present" (**Demonstrated** [44][45]). For other lab-backed checks, see the library's studies of the Linux TCP flaw and npm supply-chain attacks.
- **Web shells outlive patches.** Upgrading closes the door but leaves whatever already came through it, which is why the vendor's reply on issue #354 told victims to remove lingering shells after upgrading (**Confirmed** [18]). The Log4Shell study records the same web-shell technique after another internet-facing flaw.

Sources

All sources opened on 4 November 2026.

#	Source	URL	Opened	Grade
1	Collabora, repository advisory GHSA-g3vx-3m76-fghh (published 14 Oct 2026)	github.com/CollaboraOnline/online/security/advisories/GHSA-g3vx-3m76-fghh	2026-11-04	Confirmed
2	CVE record CVE-2026-110447 (CNA container and CISA ADP SSVC)	cve.org/CVERecord?id=CVE-2026-110447	2026-11-04	Confirmed

#	Source	URL	Opened	Grade
3	NVD, CVE-2026-110447 (detail page and REST API record)	nvd.nist.gov/vuln/detail/CVE-2026-110447	2026-11-04	Confirmed
4	CISA, Known Exploited Vulnerabilities catalog entry and JSON feed	cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2026-110447	2026-11-04	Confirmed
5	CISA, BOD 26-04 implementation guidance	cisa.gov/news-events/directives/bod-26-04-implementation-guidance-prioritizing-security-updates-based-risk	2026-11-04	Confirmed
6	GitHub global advisory GHSA-f97p-r72q-64h2 (unreviewed NVD mirror)	github.com/advisories/GHSA-f97p-r72q-64h2	2026-11-04	Confirmed
7	Nextcloud, security advisories repository (advisory list)	github.com/nextcloud/security-advisories/security/advisories	2026-11-04	Confirmed
8	NVD, CVE-2025-66208	nvd.nist.gov/vuln/detail/CVE-2025-66208	2026-11-04	Confirmed
9	`richdocumentscode` `proxy.php` at tag 26.4.302	github.com/CollaboraOnline/richdocumentscode/blob/26.4.302/proxy.php	2026-11-04	Confirmed
10	`richdocumentscode` `proxy.php` at tag 25.4.202 (and at 26.4.104)	github.com/CollaboraOnline/richdocumentscode/blob/25.4.202/proxy.php	2026-11-04	Confirmed
11	Fix commit 6cc8dae, "tidy up how the coolwsd launch command is built"	github.com/CollaboraOnline/richdocumentscode/commit/6cc8dae54c92bae27d53c54b9898cf1123ca2066	2026-11-04	Confirmed
12	Compare 26.4.302...26.4.303	github.com/CollaboraOnline/richdocumentscode/compare/26.4.302...26.4.303	2026-11-04	Confirmed
13	`richdocumentscode` releases	github.com/CollaboraOnline/richdocumentscode/releases	2026-11-04	Confirmed
14	`richdocumentscode` CHANGELOG at 26.4.502	github.com/CollaboraOnline/richdocumentscode/blob/26.4.502/CHANGELOG.md	2026-11-04	Confirmed
15	`richdocumentscode` `appinfo/info.xml` at 26.4.303 (also read at 26.4.302 and 26.4.502)	github.com/CollaboraOnline/richdocumentscode/blob/26.4.303/appinfo/info.xml	2026-11-04	Confirmed
16	Compare 26.4.303...26.4.402	github.com/CollaboraOnline/richdocumentscode/compare/26.4.303...26.4.402	2026-11-04	Confirmed
17	Compare 26.4.402...26.4.502	github.com/CollaboraOnline/richdocumentscode/compare/26.4.402...26.4.502	2026-11-04	Confirmed
18	`richdocumentscode` issue #354, "Security issue - Hack", and its comments	github.com/CollaboraOnline/richdocumentscode/issues/354	2026-11-04	Confirmed (first-hand reports); single-user claims Reported
19	Nextcloud community forum, "To Collabora Built-in User: Update ASAP"	help.nextcloud.com/t/to-collabora-built-in-user-update-asap/250516	2026-11-04	Reported (community posts); moderator warning Confirmed
20	`richdocumentscode` README	github.com/CollaboraOnline/richdocumentscode	2026-11-04	Confirmed

#	Source	URL	Opened	Grade
21	Nextcloud admin manual, occ app commands	docs.nextcloud.com/server/latest/admin_manual/occ_apps.html	2026-11-04	Confirmed
22	Nextcloud admin manual, occ file and integrity commands	docs.nextcloud.com/server/latest/admin_manual/occ_files.html	2026-11-04	Confirmed
23	Nextcloud admin manual, code signing	docs.nextcloud.com/server/latest/admin_manual/issues/code_signing.html	2026-11-04	Confirmed
24	Official Nextcloud Docker image README	github.com/nextcloud/docker	2026-11-04	Confirmed
25	Nextcloud snap README	github.com/nextcloud-snap/nextcloud-snap	2026-11-04	Confirmed
26	Nextcloud All-in-One README	github.com/nextcloud/all-in-one	2026-11-04	Confirmed
27	BleepingComputer (Bill Toulas, 15 Oct 2026), "Hackers exploit Collabora RCE flaw to backdoor Nextcloud servers"	bleepingcomputer.com/news/security/hackers-exploit-collabora-rce-flaw-to-backdoor-nextcloud-servers/	2026-11-04	Reported
28	The Hacker News (14 Oct 2026)	thehackernews.com/2026/10/hackers-backdoor-nextcloud-servers.html	2026-11-04	Reported
29	MITRE ATT&CK, T1190 Exploit Public-Facing Application	attack.mitre.org/techniques/T1190/	2026-11-04	Confirmed
30	MITRE ATT&CK, T1059.004 Unix Shell	attack.mitre.org/techniques/T1059/004/	2026-11-04	Confirmed
31	MITRE ATT&CK, T1505.003 Web Shell	attack.mitre.org/techniques/T1505/003/	2026-11-04	Confirmed
32	MITRE ATT&CK, T1027 Obfuscated Files or Information	attack.mitre.org/techniques/T1027/	2026-11-04	Confirmed
33	MITRE ATT&CK, T1140 Deobfuscate/Decode Files or Information	attack.mitre.org/techniques/T1140/	2026-11-04	Confirmed
34	MITRE ATT&CK, T1082 System Information Discovery	attack.mitre.org/techniques/T1082/	2026-11-04	Confirmed
35	MITRE ATT&CK, T1552.001 Credentials In Files (considered, left out)	attack.mitre.org/techniques/T1552/001/	2026-11-04	Inferred mapping
36	MITRE CWE-78	cwe.mitre.org/data/definitions/78.html	2026-11-04	Confirmed
37	MITRE CAPEC-88 OS Command Injection, and the library's `data/weaknesses/cwe.jsonl`	capec.mitre.org/data/definitions/88.html	2026-11-04	Confirmed
38	MITRE CAPEC-650 Upload a Web Shell to a Web Server, and the library's `data/weaknesses/capec.jsonl`	capec.mitre.org/data/definitions/650.html	2026-11-04	Confirmed
39	MITRE D3FEND, File Integrity Monitoring, and the library's D3FEND pages under `/mitre/d3fend/`	d3fend.mitre.org/technique/d3f:FileIntegrityMonitoring/	2026-11-04	Confirmed
40	MITRE D3FEND, Software Update	d3fend.mitre.org/technique/d3f:SoftwareUpdate/	2026-11-04	Confirmed (page); binding Inferred

#	Source	URL	Opened	Grade
41	TeamStarWolf library, `navigator/library-layers/`	github.com/TeamStarWolf/TeamStarWolf/tree/main/navigator/library-layers	2026-11-04	Confirmed
42	TeamStarWolf lab plan for CVE-2026-110447 (`plan.json`)	Lab capture (not published)	2026-11-04	Inferred (proposed rules)
43	Lab capture `01-setup.txt` (setup, quarantine review, fixed `proxy.php` listing; the screenshot is a trimmed rendering of it)	Lab capture (not published); screenshot in Part 4	2026-11-04	Demonstrated
44	Lab capture `02-test.txt` (version check)	Lab capture (not published); quoted in Part 4	2026-11-04	Demonstrated
45	Lab capture `03-exposure.txt` and `03-exposure.png` (exposure check)	Lab capture (not published); screenshot in Part 4	2026-11-04	Demonstrated
46	Lab capture `04-mitigation.txt` and `04-mitigation.png` (fix diff, detection silence)	Lab capture (not published); screenshot in Part 4	2026-11-04	Demonstrated
47	Lab capture `05-cleanup.txt` and `05-cleanup.png` (cleanup)	Lab capture (not published); screenshot in Part 4	2026-11-04	Demonstrated

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Threat Actors, Malware Families, Notable Incidents: no actor or malware family is attributed to this exploitation
- Vulnerability Prioritization Reference, Vulnerability Management Reference, Triage a CVE
- Web Application Security Reference
- Other lab-backed studies: Ghostcat, the Tomcat AJP file read in the lab; ProFTPD mod_copy; Magento and Adobe Commerce PolyShell, another unauthenticated web flaw that ended in web shells; Node.js Brotli decoder, another version check that tells a vulnerable build from a fixed one
- Other vulnerability studies: PHP2Shell and the October 2026 attack wave, which notes the Collabora CODE KEV addition; Log4Shell, another internet-facing flaw followed by web shells (T1505.003); the Linux TCP use-after-free

- Techniques: T1190 Exploit Public-Facing Application, T1059.004 Unix Shell, T1505.003 Web Shell, T1027 Obfuscated Files or Information, T1140 Deobfuscate/Decode Files or Information, T1082 System Information Discovery
- CAPEC: CAPEC-88 OS Command Injection, CAPEC-650 Upload a Web Shell to a Web Server
- D3FEND: File Integrity Monitoring, Process Spawn Analysis, File Eviction, Inbound Traffic Filtering, Application Protocol Command Analysis, all countermeasures
- Navigator layers, including this study's layer, nextcloud-richdocumentscode-cve-2026-110447.json
- All case studies